

Cloud — IaaS, PaaS, SaaS e PA

Modelli di erogazione e responsabilità condivisa; per la PA anche qualificazione ACN e Polo Strategico Nazionale.

Da ricordare

In SaaS la patch dell'infrastruttura NON è in capo all'amministrazione utente. Chiediti sempre: cosa gestisco io?

1. IaaS — Infrastructure as a Service

L'ente ottiene compute, storage e rete virtuali e gestisce sistemi operativi, middleware e applicativi.

Nel modello IaaS il cloud provider eroga risorse infrastrutturali virtualizzate: macchine virtuali, volumi di storage, reti virtuali, bilanciatori di base. L'amministrazione installa e patcha il sistema operativo, configura runtime/middleware e applica le policy di sicurezza a livello di guest (hardening, antivirus, agent di monitoraggio). Il provider gestisce facility, hardware e strato di virtualizzazione.

È il modello più vicino al datacenter tradizionale «affittato»: massima flessibilità su stack e rete, ma anche maggiori responsabilità operative sull'ente o sul suo fornitore di managed services. Utile per carichi custom, legacy, appliance virtuali o quando serve controllo fine su sistemi operativi e segmentazione di rete.

In esame: elenca cosa gestisce il provider (hardware, hypervisor, facility) e cosa resta all'ente (OS, app, dati, identity degli admin, backup delle VM se non incluso). Collega sempre a shared responsibility: «chi patcha cosa» è la domanda chiave. Domanda classica: in IaaS puro la patch del SO guest è dell'amministrazione.

Glossario

IaaS — Infrastructure as a Service: infrastruttura virtuale self-service.

Shared responsibility — Riparto dei doveri di sicurezza tra provider cloud e amministrazione cliente.

In prova: Domanda classica: «Chi patcha il sistema operativo in IaaS?» !' l'amministrazione (o chi opera per lei), non il provider di sola IaaS.

Riferimenti: Strategia Cloud PA

2. PaaS — Platform as a Service

La piattaforma (runtime, DB gestiti, toolchain) è del provider; l'ente gestisce codice, configurazione applicativa e dati.

Il PaaS offre un ambiente pronto per sviluppare ed eseguire applicazioni: runtime, middleware, spesso database gestiti, code, storage object e strumenti CI/CD. L'amministrazione si concentra sul codice e sulla logica di business, senza amministrare hypervisor o, in molti casi, il sistema operativo sottostante, che resta in carico al provider.

Vantaggi: time-to-market, scaling facilitato, meno burden infrastrutturale, patch del runtime spesso gestite dal fornitore. Rischi: lock-in su servizi proprietari della piattaforma, vincoli su linguaggi/runtime, necessità di progettare portabilità, osservabilità e export dei dati. La responsabilità sui dati personali e sull'applicazione resta dell'ente titolare.

Confronto utile in prova: IaaS = controlli OS; PaaS = controlli app/dati; SaaS = controlli su uso e configurazione funzionale. Se chiedono «non gestisco il SO ma carico il codice e configuro il DB gestito» !' PaaS. Cita un esempio tipico (app web su runtime gestito + database as a service).

Glossario

PaaS — Platform as a Service: piattaforma gestita per build e run delle applicazioni.

Runtime gestito — Ambiente di esecuzione (es. container/app service) mantenuto dal provider.

In prova: Se chiedono «non gestisco il SO ma carico il codice» !' PaaS.

Riferimenti: Strategia Cloud PA

3. SaaS — Software as a Service

Applicativo completo erogato via rete: l'ente configura utenti, ruoli e opzioni; non patcha l'infrastruttura sottostante.

Nel SaaS il fornitore eroga l'applicazione completa (posta, collaboration, CRM, ticketing, protocollo in cloud, ecc.) accessibile tipicamente via browser o client ufficiale. L'amministrazione gestisce utenze, permessi, integrazioni (SSO/SPID), retention e dati di business inseriti nel servizio, ma non amministra server, SO o patch infrastrutturali dell'applicativo.

Per la PA sono critici: trattamento dati (ruoli titolare/responsabile ex art. 28 GDPR), residenza e classificazione dei dati, clausole contrattuali, export e exit, logging degli accessi admin, integrazione con SPID/CIE. Il modello SaaS sposta molto rischio operativo sul provider, ma non elimina accountability dell'ente sul trattamento e sulla scelta del servizio qualificato ove richiesto.

Trappola d'esame: attribuire all'ente utente la patch di hypervisor/SO in un SaaS puro. Risposta corretta: l'ente si occupa di configurazione, accessi, classificazione e uso corretto; il provider dell'infrastruttura e dell'applicazione. Ricorda la frase d'oro: in SaaS la patch infrastrutturale non è dell'amministrazione utente.

Glossario

SaaS — Software as a Service: software pronto all'uso erogato come servizio.

Responsabile del trattamento — Fornitore che tratta dati per conto del titolare PA, con contratto ex art. 28 GDPR.

In prova: Frase da ricordare: in SaaS la patch infrastrutturale non è dell'amministrazione utente.

Riferimenti: Strategia Cloud PA · GDPR art. 28

4. On-premise vs cloud

On-premise massimizza controllo fisico; il cloud offre elasticità e costi operativi diversi, con vincoli su dati e residenza.

L'infrastruttura on-premise è gestita nei locali o nel datacenter sotto controllo diretto dell'ente: pieno controllo su hardware, rete e accessi fisici, ma investimenti capitali, capacità da dimensionare «per picco», refresh tecnologico e oneri di manutenzione su personale interno o fornitori. Il cloud (pubblico, privato o hybrid) sposta verso modelli a consumo, elasticità e servizi gestiti.

La scelta non è solo economica: dipendono classificazione dei dati, requisiti di latenza e connettività, competenze interne, vincoli regolatori PA (qualificazione ACN, PSN), strategie di backup/DR e rischio di lock-in. Spesso si adottano modelli ibridi: sistemi legacy o ad altissima criticità a terra, nuovi servizi in cloud qualificato.

In sintetica: due vantaggi e due rischi per ciascun modello, poi il criterio decisivo per la PA = classificazione dati + conformità al quadro ACN/PSN + competenze. Non contrapporre «sicuro vs insicuro»: parla di controllo, responsabilità condivisa e misure adeguate al rischio.

Glossario

On-premise — Infrastruttura ospitata e gestita presso l'ente o un datacenter sotto suo controllo diretto.

Hybrid cloud — Combinazione di risorse on-premise e cloud, integrate operativamente.

In prova: Non contrapporre «sicuro vs insicuro»: parla di controllo, responsabilità condivisa e vincoli di classificazione.

Riferimenti: Strategia Cloud PA · Quadro ACN

5. Classificazione dati: ordinario, critico, strategico

La classificazione guida dove possono risiedere i dati della PA e quali servizi cloud sono ammessi.

Nel percorso di cloud enablement della PA italiana i dati e i servizi sono classificati, in sintesi didattica, in ordinari, critici e strategici in base a impatto su sicurezza nazionale, continuità dei servizi essenziali, riservatezza e sensibilità. La classificazione non è un'etichetta informatica fine a sé stessa: determina i vincoli di deployment e il livello di cloud qualificato utilizzabile.

Dati/servizi a criticità crescente richiedono ambienti più controllati (cloud qualificati di livello adeguato, PSN, misure rafforzate di cifratura, logging e accesso). L'ente deve inventariare trattamenti e servizi, classificarli con le strutture competenti e solo dopo scegliere il target infrastrutturale. Errori di classificazione espongono a non conformità e a rischi operativi gravi.

Per l'esame: spiega i tre livelli in termini di impatto e collega «più critico !» più vincoli». Evita di inventare elenchi di articoli o percentuali; resta sul ragionamento ACN/strategia cloud PA. Esempio: sito informativo istituzionale "" anagrafe critica "" asset strategici di sicurezza nazionale.

Glossario

Dato/servizio strategico — Asset a massimo impatto; tipicamente soggetto ai vincoli più stringenti di collocation/qualificazione.

Dato ordinario — Asset a impatto contenuto; con più opzioni di cloud qualificato, sempre nel rispetto della privacy.

In prova: Collega sempre classificazione !' scelta del tipo di cloud/PSN, non solo alla cifratura.

Riferimenti: Strategia Cloud PA · Quadro ACN sulla qualificazione cloud

6. PSN e cloud qualificati ACN

Il Polo Strategico Nazionale e i cloud qualificati ACN sono i riferimenti di adozione cloud per molte pubbliche amministrazioni.

L'Agenzia per la Cybersicurezza Nazionale (ACN) gestisce il percorso di qualificazione dei servizi cloud per la PA: i provider devono dimostrare requisiti di sicurezza, affidabilità, trasparenza e conformità per poter erogare servizi alle amministrazioni in funzione della classificazione dei dati/servizi. Non tutti i cloud commerciali «di mercato» sono automaticamente utilizzabili per ogni classe di dato pubblico.

Il Polo Strategico Nazionale (PSN) è l'infrastruttura di riferimento per ospitare servizi e dati a elevata criticità della PA, in un modello di consolidamento e rafforzamento della sicurezza nazionale del cloud pubblico. Le amministrazioni devono pianificare migrazioni e adoption secondo le roadmap, i cataloghi dei servizi qualificati e i vincoli vigenti, coinvolgendo RTD e strutture di sicurezza.

Risposta da concorso: ACN = qualificazione e cybersicurezza nazionale; PSN = polo infrastrutturale strategico; classificazione dati = criterio di scelta del target. Distingui da AgID (agenda digitale, linee guida su riuso/documento/interoperabilità) senza contrapposizioni inutili: operano su piani diversi e complementari.

Glossario

ACN — Agenzia per la Cybersicurezza Nazionale: tra i compiti, qualificazione dei servizi cloud per la PA.

PSN — Polo Strategico Nazionale: infrastruttura cloud di riferimento per servizi/dati ad alta criticità.

In prova: Non confondere AgID e ACN. Per cloud PA cita qualificazione ACN + PSN + classificazione.

Riferimenti: ACN — qualificazione cloud · Polo Strategico Nazionale